Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 1.8 / COMPANION WORKBOOK

Tiered administration

Admin seats, the tier rules & where privilege may sign in

Build the administration plane before the fleet: three administration seats on two machines in VLAN 60 (the endpoint seat runs as a virtual machine on the server seat), directory-enforced tier restrictions proven by both successful in-tier sessions and logged out-of-tier denials, and the move of earlier console work — SBD-DHCP01's administration and the assessment tools — onto the seats.

MATERIALS EDITION 2.0 / COURSE 1.8

Updated 14 October 2026 · sbd-tiered-admin

NAME _____ / DATE _____

START HERE / YOUR LEARNING PATH

Table of contents

Read each lesson alongside the interactive guide and the video. Use the record tables to write down what you actually observe — the workbook is your evidence, not the guide.

Before you start

01 Design the tiers and the admin seats

02 Build the administration systems

03 Restrict where privilege can sign in

04 Prove the tiers end to end

05 Move the scan tools, rescan, and hand off

Course review and sign-off

> **HOW TO USE IT** Each lesson page has the same shape: what you will learn, the build steps, the commands that verify them, and a record table. Fill the table from your own environment — never from the sample values.

Before you start

This course builds the administration plane before the fleet exists: a tiered model where privileged sessions only ever start from dedicated hosts. The model's rule is strict — the jump systems administer; they browse nothing, read no mail, and accept no inbound sessions from user space. To save a machine, the three seats run on two: the endpoint seat is a virtual machine on the server seat, the arrangement the Defense Information Systems Agency (DISA) Windows Privileged Access Workstation (PAW) Security Technical Implementation Guide (STIG) allows where workstations are scarce. The Tier 0 seat runs no virtual machines. Work that earlier courses did at consoles moves onto the seats: SBD-DHCP01's administration (course 1.7) to the Tier 1 seat, and the assessment tools and evidence (course 1.4) from the domain controllers to AdminJumpBox01, with a Tier 1 copy of the tools on SBD-ADMIN-SRV01.

Prerequisites

- ☐ Complete course 1.7: SBD-DHCP01 serves VLAN 80 and is run at its console by course 1.7's SBD Tier 1 Admins, with the VLAN 80 test client still in place. Course 1.6's two-tier PKI and course 1.5's OU structure, with the Admin OU, are already built, and the network's routing and default-deny segmentation, with its access control list (ACL) register, are in place.
- ☐ Provision Windows Server hosts for the two physical administration seats in VLAN 60, AdminJumpBox01 (.10) and SBD-ADMIN-SRV01 (.20), and plan SBD-ADMIN-PC01 (.30) as a virtual machine on SBD-ADMIN-SRV01 running the Enterprise or Education edition of the Windows client. SBD-ADMIN-SRV01 needs hardware virtualization and an input–output memory management unit (IOMMU); where it is itself a virtual machine, turn on nested virtualization and media access control (MAC) address spoofing for it; where either seat is a virtual machine in your lab, turn off its hypervisor time synchronization, as course 1.3 requires of every virtual machine; and record what your lab can't provide, such as Credential Guard, as a lab limitation.
- ☐ Decide the privileged accounts: separate admin identities per tier, never daily-driver accounts with admin rights.
- ☐ Have course 1.4's media set at hand — SCC, STIG Viewer, and the benchmarks, with connected-side-hashes.csv — because lesson 5 moves the assessment tools from the domain controllers onto AdminJumpBox01 and gives SBD-ADMIN-SRV01 its own Tier 1 copy.

What this course builds

- Stand up single-purpose administration seats for each tier in the Admin OU, with the endpoint seat a virtual machine on the server seat.
- Enforce and prove per-tier sign-in restrictions with captured denial evidence.
- Move SBD-DHCP01's administration and the assessment tools onto the seats, each tier on its own.

Systems in scope

RECORD	YOUR OBSERVATION
AdminJumpBox01 — name, address, OS build	

© 2026 Secure By Design Team LLC.

RECORD	YOUR OBSERVATION
SBD-ADMIN-SRV01 — name, address, OS build	
SBD-ADMIN-PC01 — name, address, OS build	

LESSON 01 / ABOUT 20 MIN

Design the tiers and the admin seats

> **WHY THIS MATTERS** Tiering is one sentence with teeth: credentials that control a tier never touch a less-trusted one. Write that policy against the OU structure and give each tier its seat and its group — all before any host is built.

In this lesson you will

- Define the tiers and map each to systems, OUs, and admin accounts.
- Assign each tier its admin seat under the Defense Information Systems Agency (DISA) privileged access workstation (PAW) rules.
- Write the credential rule each tier enforces.

Follow the build

1. Define three tiers against what exists, using Microsoft's rule: anything that can control a Tier 0 system is Tier 0. Tier 0 is the identity and trust fabric (DCs, both CAs, PKI-MGMT01) plus what controls it — the hypervisor hosts and their console, the core router's management, and the DC-facing parts of the tools that patch, protect, scan, monitor, and back up the DCs. Tier 1 is the member servers; Tier 2 the user endpoints. Map each tier to its OUs: Tier 0 to the Domain Controllers OU plus a new Tier 0 Servers OU for SBD-SUBCA01 and SBD-PKI-MGMT01 (lesson 3 moves them out of the Servers OU), Tier 1 to the Servers OU, where course 1.7's SBD-DHCP01 already sits, and Tier 2 to the Workstations OU.
2. Assign the admin seats under DISA's Windows PAW Security Technical Implementation Guide (STIG): each privileged access workstation serves one tier (V-243445), and the one that manages the domain controllers is reserved for that work (V-243454, high severity). Where workstations are scarce, V-243445 allows one exception: lower-tier admin accounts in a virtual machine on a higher-tier seat, with the higher-tier accounts on the host. This network uses it to run three seats on two machines: AdminJumpBox01 for Tier 0, running no virtual machines, and SBD-ADMIN-SRV01 for Tier 1, which also runs SBD-ADMIN-PC01, the Tier 2 seat, as a virtual machine with its own name and address. Record the STIG differences in the exception record (AdminJumpBox01 manages all of Tier 0, not only the domain controllers; both physical seats run Windows Server where the STIG expects a Windows client, V-243447), and the PAW rules left open, such as smart-card sign-in (V-243457) and application allowlisting (V-243450, V-243451).
3. Write the credential rule per tier: a Tier 0 account signs in only on Tier 0 systems and AdminJumpBox01; Tier 1 admins work on the SBD-ADMIN-SRV01 host; Tier 2 admins only inside the SBD-ADMIN-PC01 virtual machine, never on its host. The audit custodian uses separate accounts and sessions on SBD-ADMIN-SRV01 that ordinary server operators cannot use. Each administrator gets separate per-tier accounts — the daily account holds no admin rights anywhere — gathered in one group per role in the Admin OU: SBD Tier 0 Admins, SBD Tier 1 Admins (course 1.7 created it for SBD-DHCP01), SBD Tier 2 Admins, and SBD Audit Custodians in this sample.
4. Add the register rows this course needs: VLAN 60 to each tier's management ports (rules A01–A04 in Inside the Network), and explicit denies from VLAN 80 into VLAN 60 — user space never initiates toward the admin plane. A02 already names SBD-DHCP01, whose administration moves to SBD-ADMIN-SRV01 in lesson 2.

Check your result

```
# At SBD-DC01's console until lesson 2 builds AdminJumpBox01: OU targets, current account
separation, and the role groups.
Get-ADOrganizationalUnit -Filter * | Select-Object Name, DistinguishedName
Get-ADGroupMember 'Domain Admins' | Select-Object Name, SamAccountName
'SBD Tier 0 Admins', 'SBD Tier 2 Admins', 'SBD Audit Custodians' | ForEach-Object { New-
ADGroup $_ -GroupScope Global -Path 'OU=Admin,OU=SBD,DC=sbd,DC=test' }
Get-ADGroup -SearchBase 'OU=Admin,OU=SBD,DC=sbd,DC=test' -Filter * | Select-Object Name
# SBD Tier 1 Admins came from course 1.7
```

> **WHAT SUCCESS LOOKS LIKE** The tier map names systems, OUs, admin seats, accounts, and groups per tier, with SBD-ADMIN-PC01 a virtual machine on SBD-ADMIN-SRV01; the exception record holds the seat plan's STIG differences and open PAW items; the role groups exist in the Admin OU; and the register has the new permit and deny rows with owners.

Your record

Evidence to keep: Keep the tier access matrix, the seat plan with its STIG rationale and recorded differences, the per-administrator account plan with its groups, and the updated register rows.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What is the one-sentence tiering rule?

> **REMEMBER** Three tiers, each with its systems, OU, admin seat, accounts, and group. The credential rule is written before any host enforces it. Each tier's management path and the VLAN 80 → VLAN 60 deny are register rows.

Microsoft · Privileged access workstations and the access model

Microsoft · Tier model for Active Directory Domain Services

DISA · STIGs Document Library (Windows PAW STIG)

NIST · SP 800-53 Rev. 5 security controls

LESSON 02 / ABOUT 45 MIN

Build the administration systems

WHY THIS MATTERS Privileged work gets dedicated, hardened seats: a Tier 0 jump host that runs no virtual machines, and a server-administration seat that also runs the endpoint seat as a virtual machine. Each seat sits in the Admin OU, does nothing but administer, and is maintained by its own group.

In this lesson you will

- Link the hardening policies to the Admin OU's computer sub-OUs, then build the two seats and the seat virtual machine into them, each with its own Group Policy object (GPO) and maintenance group.
- Run SBD-ADMIN-PC01 as a virtual machine on SBD-ADMIN-SRV01 with its own name and address, and close the channels that share data between host and guest.
- Keep the seats single-purpose, with each tier's tools on its own seat, and move earlier courses' console work onto them.
- Register and restrict their management paths.

Follow the build

1. Create two computer sub-OUs under the Admin OU — Admin Servers for AdminJumpBox01 and SBD-ADMIN-SRV01, Admin Workstations for the SBD-ADMIN-PC01 virtual machine — and link course 1.5's STIG GPOs to them before any seat joins: the member-server computer policy, the user policy, and the loopback (Merge) GPO to Admin Servers, and the Windows client computer and user policies, which course 1.5 imported but left unlinked, with the same loopback GPO to Admin Workstations. Course 1.5 linked them only to the Domain Controllers and Servers OUs, so without this step the seats would boot unhardened.
2. Build AdminJumpBox01 and SBD-ADMIN-SRV01 as clean Windows Server installs and join both into Admin Servers, so the hardening applies from first boot; AdminJumpBox01 never gets the Hyper-V role or a virtual machine, because the seat that manages the domain controllers never hosts a lower tier. Give every seat its own seat GPO, linked above the STIG GPO — one on Admin Workstations, and two on Admin Servers, each filtered to its seat (deny Apply group policy to the other) — that makes the seat's own maintenance group (SBD PAW Maintenance T0, T1, or T2 in this sample), used for nothing else, the only domain group in its local Administrators: the PAW STIG gives tier accounts user rights only on their seat (V-243456, V-243462), and no group spans tiers. SBD-ADMIN-SRV01's GPO also adds NT VIRTUAL MACHINE\Virtual Machines (*S-1-5-83-0) to Create symbolic links beside Administrators: Group Policy replaces the right's local value, and without that entry, which the STIG accepts on Hyper-V hosts, the virtual machine won't start. Lesson 3 adds each seat's sign-in rights.
3. Add the Hyper-V role to SBD-ADMIN-SRV01 and create SBD-ADMIN-PC01 as a generation 2 virtual machine with Secure Boot and a virtual Trusted Platform Module (TPM), set to start whenever the host starts. The Windows client needs the TPM, and Credential Guard, which the Windows client STIG requires, runs in a virtual machine only on generation 2 and on a host with an input–output memory management unit (IOMMU). Connect it through an external virtual switch on the seat's VLAN 60 adapter with its own address, 10.0.60.30, install the Enterprise or Education edition of the Windows client, and join it into Admin Workstations. Because it keeps its own name and address, the register's rule for SBD-ADMIN-PC01 (A03) still names it alone, never its host.

© 2026 Secure By Design Team LLC.

4. Close the channels that share data between host and guest, because the virtual machine separates the tiers only while they share nothing they don't need: turn off enhanced session mode on the host, so the console carries only screen, keyboard, and mouse, with no shared clipboard, drives, or devices; keep the Guest Service Interface off, so the host can't copy files in; turn off Key-Value Pair Exchange, which passes data both ways; turn off Time Synchronization, because the guest takes its time from the domain like every virtual machine (course 1.3); and add no shared folders. What remains, the basic integration services and PowerShell Direct (which can run commands and copy files either way), needs Hyper-V administrator rights on the host, and PowerShell Direct also needs an account in the guest. Administrators who hold both a Tier 1 and a Tier 2 account open the console from the host with the Tier 1 account, which SBD-ADMIN-SRV01's seat GPO puts in the local Hyper-V Administrators group — the one privileged local group the PAW STIG lets a Hyper-V seat fill (V-243463), so they need no host administrator rights — and sign in inside with the Tier 2 one. One person uses the console at a time and signs out of the virtual machine before closing it, because without enhanced session mode the next person to connect takes over an open desktop; a Tier 2-only administrator needs a seat of their own.
5. Strip them to purpose: no browsing to anything but internal admin interfaces, no mail, no file shares hosted, and the management tools for exactly their tier — Remote Server Administration Tools (RSAT) on the two server seats, endpoint tooling inside the SBD-ADMIN-PC01 virtual machine — with SBD-ADMIN-SRV01 running that one virtual machine and no other. Then move the console work earlier courses did onto the seats: Tier 0 directory, DNS, and DHCP authorization work moves from SBD-DC01's console to AdminJumpBox01, so remove the DHCP management tools course 1.7 added to SBD-DC01; and SBD-DHCP01 is administered from SBD-ADMIN-SRV01 with Tier 1 accounts, over the remote desktop and remote management paths rule A02 registers, no longer at its console.
6. Register the management paths: VLAN 60 to Tier 0 and Tier 1 ports (remote desktop 3389, remote management 5985–5986, AD Web Services 9389 to the domain controllers, SSH 22 for the domain-joined Linux servers) from the specific admin host each tier allows, and the router's management on VLAN 100 from AdminJumpBox01 only; keep the VLAN 80 → VLAN 60 deny from lesson 1 in force. Require the admin seats' own local firewalls, the virtual machine's included, to accept management inbound from nowhere — sessions originate here, they never terminate here, so neither the host nor its guest can manage the other over the network. On both domain controllers, scope the existing Remote Desktop, Windows Remote Management, and Active Directory Web Services firewall rules to AdminJumpBox01 and VLAN 10: allow rules add up, so a new, narrower rule would not restrict the broad ones already enabled.

Check your result

```
Get-ADComputer -SearchBase 'OU=Admin,OU=SBD,DC=sbd,DC=test' -Filter * | Select-Object
Name, DistinguishedName
Get-GPInheritance -Target 'OU=Admin Servers,OU=Admin,OU=SBD,DC=sbd,DC=test'
Get-GPInheritance -Target 'OU=Admin Workstations,OU=Admin,OU=SBD,DC=sbd,DC=test'
Get-LocalGroupMember Administrators   # each seat: its maintenance group, no tier group
# On SBD-ADMIN-SRV01: its one virtual machine, and what host and guest share.
Get-VM | Select-Object Name, Generation, State, AutomaticStartAction   # Start
(Get-VMFirmware SBD-ADMIN-PC01).SecureBoot; (Get-VMSecurity SBD-ADMIN-PC01).TpmEnabled
Get-VMHost | Select-Object EnableEnhancedSessionMode   # False
Get-VMIntegrationService SBD-ADMIN-PC01 | Select-Object Name, Enabled   # Guest Service
Interface, Key-Value Pair Exchange, Time Synchronization: False
Get-LocalGroupMember 'Hyper-V Administrators'   # the console users' Tier 1 accounts
Resolve-DnsName SBD-ADMIN-PC01.sbd.test   # 10.0.60.30
Invoke-Command SBD-DHCP01.sbd.test { Get-DhcpServerv4Scope }   # Tier 1 account, over
remote management (A02)
# Inside SBD-ADMIN-PC01: Credential Guard is running when the list includes 1.
```

```
$dg = Get-CimInstance Win32_DeviceGuard -Namespace root\Microsoft\Windows\DeviceGuard
$dg.SecurityServicesRunning
w32tm /query /source   # a domain controller, never the VM IC Time Synchronization
Provider
# On AdminJumpBox01: Hyper-V stays Available, never Installed.
Get-WindowsFeature Hyper-V | Select-Object Name, InstallState
Uninstall-WindowsFeature RSAT-DHCP -ComputerName SBD-DC01   # course 1.7's DHCP tools
leave the controller
Test-NetConnection SBD-DC01.sbd.test -Port 5985
gpresult /r /scope:computer
```

WHAT SUCCESS LOOKS LIKE AdminJumpBox01 and SBD-ADMIN-SRV01 sit in Admin Servers and the SBD-ADMIN-PC01 virtual machine in Admin Workstations, with the STIG and seat GPOs applied; each seat's local Administrators holds its maintenance group, no tier group; SBD-ADMIN-SRV01 runs only SBD-ADMIN-PC01 (10.0.60.30, generation 2, Secure Boot on, TPM, Credential Guard, starts with the host) with enhanced session mode, the Guest Service Interface, Key-Value Pair Exchange, and Time Synchronization off, and the guest takes its time from a domain controller; AdminJumpBox01 has no Hyper-V role; SBD-DHCP01 is managed from SBD-ADMIN-SRV01 and the DHCP tools are gone from SBD-DC01; management ports answer from the correct seat per tier; and user space can open no session toward VLAN 60.

Your record

Evidence to keep: Record each seat's build sheet (for the virtual machine: host, generation, address), OU placement, GPO links, gpresult output, local group members, host and guest settings with the guest's time source, the administration moves, and register rows.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why do the admin hosts run nothing but administration?

REMEMBER Two seats and a seat virtual machine, hardened from first boot; AdminJumpBox01 runs no virtual machines. Each seat has its own maintenance group; host and guest share no clipboard, drives, or folders. Management flows outward only; VLAN 60 accepts nothing inbound. Every management path is a register row.

Microsoft · Privileged access workstations and the access model

DISA · STIGs Document Library (Windows PAW STIG)

Microsoft · Configure a firewall for Active Directory domains

Microsoft · Manage Hyper-V Integration Services

Microsoft · Hyper-V Virtual Machine Connection

Microsoft · Plan for Hyper-V security in Windows Server

Microsoft · Credential Guard overview

Microsoft · Hyper-V virtual machine creation troubleshooting guidance

LESSON 03 / ABOUT 45 MIN

Restrict where privilege can sign in

> **WHY THIS MATTERS** The tier rule becomes real when the directory refuses the wrong sign-in. Give Tier 0 servers their own OU first, deny privileged logons on lower tiers by policy, protect the highest accounts, and make the refusal something you can show in a log.

In this lesson you will

- Move the Tier 0 member servers into their own OU before any deny policy lands.
- Enforce per-tier sign-in restrictions and administrators with Group Policy — on the tier OUs, every admin seat, and both sides of the seat virtual machine — and record the one network-logon exception.
- Protect Tier 0 accounts and prove a cross-tier sign-in is denied and logged.

Follow the build

1. Create the Tier 0 Servers OU (OU=Tier 0 Servers,OU=SBD,DC=sbd,DC=test) with deletion protection, link course 1.5's member-server STIG GPOs to it — the computer policy, the user policy, and the loopback GPO — so nothing loses its hardening, and move SBD-SUBCA01 and SBD-PKI-MGMT01 there. Both are Tier 0, and the Servers OU is about to deny Tier 0 sign-ins — left there, they would lock Tier 0 out of its own systems.
2. Create one tier logon GPO for the Servers OU — now Tier 1 only — and one for the Workstations OU, and never link either to the Domain Controllers or Tier 0 Servers OUs. User rights don't merge across GPOs: for each right, the highest-precedence GPO that sets it wins, so each list repeats the entries course 1.5's STIG GPO sets for that right (such as Domain Admins and Enterprise Admins), and the tier GPO links above the STIG GPO. On the Servers OU, give SBD Tier 0 Admins Deny log on locally, Deny log on through Remote Desktop Services, Deny log on as a batch job, and Deny log on as a service. On the Workstations OU, give SBD Tier 0 Admins and SBD Tier 1 Admins those four denies plus Deny access to this computer from the network.
3. Give the tier OUs their administrators. Now that the Tier 0 servers are out, a GPO linked only to the Servers OU adds SBD Tier 1 Admins to each server's local Administrators group and removes Domain Admins (Group Policy Preferences, Local Users and Groups), as the member-server STIG expects, so every server joined there, starting with SBD-DHCP01, is run by Tier 1 from first boot; kept apart from the tier logon GPO, it lets an OU with its own administrators, such as course 1.11's Audit Servers OU, take the denies without this grant. Then join course 1.7's VLAN 80 test client to the domain with a Tier 2 account, delegated Create Computer objects on the Workstations OU as course 1.7 did for Tier 1 on the Servers OU; the course 1.5 redirect lands it in Workstations. Add SBD Tier 2 Admins to its local Administrators and turn on remote management there, accepted only from SBD-ADMIN-PC01 (10.0.60.30), so it can serve as this course's Tier 2 test machine.
4. On the Servers OU, set Deny access to this computer from the network — SBD Tier 0 Admins plus the STIG's entries — in a separate GPO that excludes the SBD Tier 0 Console Hosts group through security filtering (deny Apply group policy). Course 1.14 adds SBD-WSUS01 to that group, so Tier 0 can manage the domain controllers' update ring there from AdminJumpBox01 with Tier 0 task accounts outside Domain Admins and Enterprise Admins (which the STIG denies network logon on member servers), and SBD-EPO01's console will join it when course 1.16, coming soon, arrives; a Kerberos network logon leaves no reusable credentials on the server. Record the exception — the group, the servers as they join it, the accounts, the reason, and its owner — in the course 1.5 exception record. Link both deny GPOs,

this one and the tier logon GPO, to any OU created later for member servers, such as course 1.11's Audit Servers OU, before a server joins it; step 3's administrators GPO never goes there.

5. Finish the seat GPOs from lesson 2 so each seat admits only its own tier, on both sides of the seat virtual machine. Allow log on locally replaces the STIG's list with Administrators and the seat's own groups: SBD Tier 0 Admins on AdminJumpBox01 (every Tier 0 account, Domain Admins and Enterprise Admins members included), SBD Tier 1 Admins and SBD Audit Custodians on SBD-ADMIN-SRV01, and SBD Tier 2 Admins inside SBD-ADMIN-PC01 (V-243452; V-243455 for the seat that manages Active Directory). The four denies plus Deny access to this computer from the network go to the other tiers: Tier 0 and Tier 1 inside the virtual machine, Tier 0 and Tier 2 on SBD-ADMIN-SRV01, Tier 1 and Tier 2 on AdminJumpBox01. The PAW STIG requires the higher-tier denies (V-243453, high severity if a Tier 0 account can sign in). Each deny list repeats the STIG GPO's entries for that right, except that AdminJumpBox01 leaves Domain Admins and Enterprise Admins out of Deny log on locally, because V-243455 admits them there. Record every STIG value these settings change in the exception record.
6. Add Tier 0 administrators to the Protected Users group so the domain refuses their weaker authentication paths, and note the behavior of the newest Windows Server release that supports this design: RC4 ticket-granting tickets are gone and legacy remote password changes are blocked for protected accounts. Protected Users accounts also cannot be delegated, which keeps the console exception free of reusable credentials. Keep the built-in safety valve: one documented break-glass account, excluded from the deny policies and used at a domain controller's console (the admin seats admit only their own tiers), with its password sealed and its every use alarmed once course 1.12 builds the alerts. Record the multifactor decision the model calls for on VLAN 60 — smart card or certificate-based sign-in for privileged accounts is the natural follow-on to course 1.6's templates — with its target date, even if implementation waits.

Check your result

```
Get-ADComputer -SearchBase 'OU=Tier 0 Servers,OU=SBD,DC=sbd,DC=test' -Filter * | Select-
Object Name
Get-ADGroupMember 'Protected Users' | Select-Object Name
Invoke-Command SBD-DHCP01.sbd.test { Get-LocalGroupMember Administrators }   # from SBD-
ADMIN-SRV01: SBD Tier 1 Admins, no Domain Admins
dsacls 'OU=Workstations,OU=SBD,DC=sbd,DC=test' /G 'SBD\SBD Tier 2 Admins:CC;computer'   #
from AdminJumpBox01 (Tier 0)
# On the test client, as its local administrator: join with a Tier 2 account, then, after
the restart, its managers
Add-Computer -DomainName sbd.test -Credential (Get-Credential) -Restart
Add-LocalGroupMember Administrators -Member 'SBD\SBD Tier 2 Admins'; Enable-PSRemoting -
Force
Set-NetFirewallRule -DisplayGroup 'Windows Remote Management' -RemoteAddress 10.0.60.30
# On the Tier 2 test machine: export the effective logon rights and read the deny lines.
secedit /export /mergedpolicy /cfg C:\Evidence\tiered-admin\user-rights.inf /areas
user_rights
Select-String -Path C:\Evidence\tiered-admin\user-rights.inf -Pattern 'SeDeny'
(Get-ADGroup 'SBD Tier 0 Admins').SID.Value   # from an admin seat: this SID must appear
on those lines
# Repeat on each seat as its maintenance account, and read who may sign in there.
Select-String -Path C:\Evidence\tiered-admin\user-rights.inf -Pattern 'SeInteractive'
# After the refused Tier 0 sign-in: event 4625 with status 0xC000015B (logon type not
granted).
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625; StartTime=(Get-
Date).AddHours(-1)} | Where-Object Message -match '0xC000015B' | Select-Object
TimeCreated, Id
```

WHAT SUCCESS LOOKS LIKE SBD-SUBCA01 and SBD-PKI-MGMT01 sit in the Tier 0 Servers OU and still accept Tier 0 sign-ins; the Servers OU's administrators GPO puts SBD Tier 1 Admins, not Domain Admins, in SBD-DHCP01's local Administrators; on the Tier 2 test machine, course 1.7's test client now in the Workstations OU, the deny rights list the Tier 0 group's SID, and a Tier 0 sign-in there is refused with Security event 4625 (status 0xC000015B); each admin seat lets only its own groups sign in and denies the other tiers — Tier 0 and Tier 1 inside SBD-ADMIN-PC01, Tier 0 and Tier 2 on SBD-ADMIN-SRV01, Tier 1 and Tier 2 on AdminJumpBox01; the exception record holds the console network-logon exception and the seat GPOs' STIG differences; Protected Users contains the Tier 0 admins; and the break-glass and MFA decisions are written.

Your record

Evidence to keep: Keep the Tier 0 Servers OU move, the logon-rights and administrators GPO reports with their links and security filtering, the user-rights exports from the test machine and each seat, the refused sign-in's 4625 event, the exception record entries, the Protected Users membership, and the break-glass and MFA decision records.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What turns the tier rule from policy into enforcement?

REMEMBER Tier 0 servers have their own OU, so the deny policies never lock Tier 0 out. Lower tiers refuse higher-tier credentials by policy, with events to prove it, and each admin seat admits only its own tier; the console network-logon exception is recorded. Tier 0 accounts sit in Protected Users, backed by the stricter defaults of the newest Windows Server release. Break-glass and MFA are written decisions, not loose ends.

Microsoft · Privileged access workstations and the access model

DISA · STIGs Document Library (Windows PAW STIG)

Microsoft · User Rights Assignment

Microsoft · Administrative tools and logon types

Microsoft · Protected Users security group

Microsoft · secedit /export

Microsoft · 4625(F): An account failed to log on

Microsoft · Active Directory domain join permissions

Microsoft · What's new in Windows Server 2025

LESSON 04 / ABOUT 30 MIN

Prove the tiers end to end

> **WHY THIS MATTERS** Run the matrix: every tier's administration works from its seat, every cross-tier attempt fails with an event, and course 1.7's addressing service still behaves exactly as registered.

In this lesson you will

- Verify each tier's management path from its designated seat.
- Capture the denial evidence for out-of-tier attempts, across the seat virtual machine's boundary too.
- Re-prove course 1.7's DHCP service and secure registration under the finished rules.

Follow the build

1. From AdminJumpBox01, manage a DC and SBD-SUBCA01 with a Tier 0 account — the Tier 0 Servers OU kept that access; from SBD-ADMIN-SRV01, manage SBD-DHCP01 with a Tier 1 account; from the SBD-ADMIN-PC01 virtual machine, opened from the host by a Tier 1 account without administrator rights there, manage the VLAN 80 test client with a Tier 2 account. Record each success with its session details, including the target's Security event 4624 (and 4672, which marks a logon that received special privileges).
2. Attempt the forbidden combinations — Tier 0 credentials at the test client, a Tier 1 account inside the SBD-ADMIN-PC01 virtual machine, a Tier 2 account on its host, a session from VLAN 80 toward VLAN 60 — and capture both the refusal the user sees and the record the infrastructure writes: Security event 4625 with status 0xC000015B on the system that refused each sign-in, and the router's deny-log entry for the VLAN 80 session.
3. Prove the virtual machine and its host stay apart: remote management attempts between SBD-ADMIN-PC01 and SBD-ADMIN-SRV01 fail in both directions at the target's firewall (they share VLAN 60, so no router sees them), and the console opens as a basic session, with no clipboard or drive sharing.
4. Renew the test client's lease and confirm course 1.7's results still hold with every restriction active — the options, the relay, and the records owned by the DHCP update account; the control plane must not have broken the service plane.
5. Reconcile the tier access matrix against what you just proved and file it with the register — the two documents together are the admin plane's assessable record.

Check your result

```
Enter-PSSession SBD-DHCP01.sbd.test   # from SBD-ADMIN-SRV01, Tier 1 account
vmconnect.exe localhost SBD-ADMIN-PC01   # same account, not elevated: the console opens
Test-NetConnection SBD-ADMIN-SRV01.sbd.test -Port 5985   # from the guest: must fail
Test-NetConnection SBD-ADMIN-PC01.sbd.test -Port 5985   # from the host: must fail
ipconfig /renew   # on the VLAN 80 test client
# Where a sign-in was refused: last hour's 0xC000015B failures (logon type not granted).
Get-WinEvent -FilterHashtable @{LogName='Security'; Id=4625; StartTime=(Get-
Date).AddHours(-1)} | Where-Object Message -match '0xC000015B' | Select-Object
TimeCreated, Id
```

> **WHAT SUCCESS LOOKS LIKE** Every in-tier path succeeds, every tested out-of-tier path fails with captured evidence — in both directions across the seat virtual machine's boundary too — and course 1.7's DHCP service and secure registration still work end to end under the full rule set.

Your record

Evidence to keep: Keep the completed tier matrix with timestamps, the denial captures, the host and guest separation results, and the post-restriction lease and registration proof.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

What pairs make the denial evidence complete?

> **REMEMBER** In-tier works, out-of-tier fails — across the seat virtual machine's boundary too — and both are on record. Addressing and registration survived the restrictions. Matrix and register reconcile as one assessable story.

Microsoft · Privileged access workstations and the access model

DISA · STIGs Document Library (Windows PAW STIG)

Microsoft · 4625(F): An account failed to log on

Microsoft · Get-WinEvent

Microsoft · Configure a firewall for Active Directory domains

Microsoft · Use local resources on Hyper-V virtual machine with VMConnect

LESSON 05 / ABOUT 25 MIN

Move the scan tools, rescan, and hand off

> **WHY THIS MATTERS** Three new seats joined, SBD-DHCP01 changed hands, and the directory's logon policy changed — the cadence fires again. Move the assessment tools off the domain controllers onto the seats, baseline the physical seats, rescan what changed, and hand the next course a network administered only from somewhere safe.

In this lesson you will

- Move SCC, STIG Viewer, and the evidence from the domain controllers onto the seats, each tier on its own.
- Baseline the two physical seats and rescan the changed systems.
- Fold the course's decisions into the standing records and write the handoff to course 1.9.

Follow the build

1. Move the assessment tools onto the seats, the last step of course 1.4's convention. Install SCC and STIG Viewer on AdminJumpBox01 from the course 1.4 media set, checked against connected-side-hashes.csv and at the same versions, and copy C:\Evidence from SBD-DC01 — the baseline and hardening folders, course 1.6's pki folder, and the course 1.7 Tier 0 folders, their manifests, and the exception record; once every set matches its manifest, remove SCC from both controllers and STIG Viewer from SBD-DC01, and retire the controllers' copy of the evidence. Each tier then assesses its own systems from its own seat: SBD-ADMIN-SRV01 gets its own copy of the tools and course 1.7's C:\Evidence\dhcp, and scans member servers locally in Tier 1 sessions, because A02 carries remote desktop and remote management, not the file-sharing and RPC ports SCC's remote scans use; SBD-ADMIN-PC01 gets its own copy in course 1.13, before the fleet's first scans.
2. Run first baselines on the two physical seats with the standard benchmark and tool versions — SBD-ADMIN-PC01's waits for its own SCC copy in course 1.13, with lesson 2's gpresult and host and guest settings as its record until then — and rescan what this course changed: SBD-SUBCA01 and SBD-PKI-MGMT01, whose move to the Tier 0 Servers OU should leave their hardening intact; SBD-DHCP01, whose administrators and logon rights now come from the tier GPOs; and both domain controllers from AdminJumpBox01, whose firewall rules lesson 2 scoped and whose results also show the moved tools reproduce course 1.5's. Complete SBD-DHCP01's STIG Viewer checklist on SBD-ADMIN-SRV01 with the manual answers course 1.7 left open.
3. Add this course's rows to the living records: the deny-logon, local Administrators, and Protected Users decisions into the exception record where they interact with STIG values, beside lesson 3's console network-logon exception, and the new permit and deny rows into the register with owners. The exception record stays one record, kept on AdminJumpBox01 by its owner, who adds the rows that Tier 1 and Tier 2 work sends in.
4. Confirm the admin hosts appear in course 1.5's quarterly cadence; privileged seats are rescanned first from now on, not last.
5. Write the handoff: administration now has a home, so course 1.9 can build SBD-REPO01 administered over SSH from SBD-ADMIN-SRV01 alone, and the logging courses (1.10–1.12) can require that collectors, the archive, and SIEM consoles are managed only from VLAN 60 — with the DC-facing

scopes from the Tier 0 seat and audit retention under the custodian's separate accounts. Say so explicitly for course 1.9 and the courses after it.

Check your result

```
# On AdminJumpBox01 (Tier 0): carry the evidence over; no output means a set matches its
manifest
Copy-Item \\SBD-DC01\C$\Evidence -Destination C:\ -Recurse
'baseline', 'hardened', 'pki', 'dhcp' | ForEach-Object { Compare-Object (Import-Csv "C:\
Evidence\$_-manifest.csv").Hash (Get-ChildItem "C:\Evidence\$_" -Recurse -File | Get-
FileHash -Algorithm SHA256).Hash }
Invoke-Command SBD-DC01, SBD-DC02 { Test-Path 'C:\Program Files*\SCAP Compliance Checker*'
}   # False once SCC is removed
# On SBD-ADMIN-SRV01 (Tier 1): course 1.7's server record, checked the same way
$s = New-PSSession SBD-DHCP01.sbd.test
Copy-Item C:\Evidence\dhcp, C:\Evidence\dhcp-manifest.csv -FromSession $s -Destination C:\
Evidence\ -Recurse
Compare-Object (Import-Csv C:\Evidence\dhcp-manifest.csv).Hash (Get-ChildItem C:\Evidence\
dhcp -Recurse -File | Get-FileHash -Algorithm SHA256).Hash
# On each seat, after its scans: this course's evidence, hashed
Get-ChildItem C:\Evidence\tiered-admin -Recurse | Select-Object Name, LastWriteTime
Get-FileHash -Algorithm SHA256 C:\Evidence\tiered-admin\*
```

> **WHAT SUCCESS LOOKS LIKE** SCC and STIG Viewer run from AdminJumpBox01 and are gone from the controllers, every moved evidence set matches its manifest, and each seat has its tier's tools; first baselines for the two physical seats and rescans of SBD-SUBCA01, SBD-PKI-MGMT01, SBD-DHCP01, and both domain controllers are filed with attributed deltas; SBD-DHCP01's checklist is complete; the exception record and register carry the new rows; and the handoff names the management constraint for course 1.9 and the logging courses.

Your record

Evidence to keep: Finish the checklist: the tool and evidence moves with their hash comparisons, the scan set, the updated records, the tier matrix, and the handoff note.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Which systems are rescanned, not baselined, this time?

REMEMBER The assessment tools and the evidence moved onto the seats, one tier per seat. Baselines, rescans, and attributed deltas are on file, and the records absorbed the course's decisions. Course 1.9 inherits a network administered only from VLAN 60.

DISA · Security Content Automation Protocol (SCC and SCAP benchmarks)

DISA · SRG/STIG tools (STIG Viewer)

NIST · SP 800-53 Rev. 5 security controls

Course review and sign-off

Before moving on, confirm each lesson left evidence behind — and that what remains open is written down, not remembered.

Lesson completion

LESSON	EVIDENCE FILED	DATE
01 Design the tiers and the admin seats	☐ yes	
02 Build the administration systems	☐ yes	
03 Restrict where privilege can sign in	☐ yes	
04 Prove the tiers end to end	☐ yes	
05 Move the scan tools, rescan, and hand off	☐ yes	

Open items carried forward

Next in the learning path

That completes course 1.8. Course 1.9 builds SBD-REPO01, the Linux repository, administered from SBD-ADMIN-SRV01 before any Linux server exists.

> **KEEP IT HONEST** Lesson completion records learning activity; it is not a system authorization decision. Your observations, not the sample values, establish what happened in your environment.

© 2026 Secure By Design Team LLC.